🔒 100 Questões Comentadas • Analista de Segurança da Informação

Privacidade • IAM • Firewalls • DevSecOps • Resposta a Incidentes • Criptografia • Monitoramento • Continuidade • Redes • Legislação

📚 100 questões estilo FGV (2015-2025) • Segurança da Informação • 100 questões

Q1

📌 PRIVACIDADE/LGPD

Segundo a LGPD (Lei 13.709/2018), o tratamento de dados pessoais sensíveis exige:

A Consentimento específico e destacado do titular

B Apenas comunicação ao encarregado

C Autorização judicial

D Anonimização completa

E Dispensa de consentimento se houver interesse legítimo

✅ **Resposta correta: A**

📘 **Comentário:** Dados sensíveis exigem consentimento explícito (art. 11).

💡 **Dica:** Dados sobre origem racial, saúde, religião, etc.

Q2

📌 RISCOS

Na gestão de riscos segundo a ISO 31000, a etapa de 'tratamento de riscos' envolve:

A Identificar ameaças

B Avaliar a probabilidade

C Selecionar opções para modificar o risco

D Monitorar controles

E Registrar incidentes

✅ **Resposta correta: C**

📘 **Comentário:** Tratamento pode ser evitar, reduzir, transferir ou aceitar o risco.

💡 **Dica:** Documentar no plano de tratamento.

Q3

📌 POLÍTICAS

Uma política de segurança da informação deve ser:

A Técnica e de acesso restrito

B Aprovada pela alta direção e comunicada a todos

C Apenas para a equipe de TI

D Revisada a cada 5 anos

E Opcional em organizações pequenas

✅ **Resposta correta: B**

📘 **Comentário:** Diretrizes de alto nível requerem patrocínio da liderança.

💡 **Dica:** Normas e procedimentos derivam da política.

Q4

📌 IAM

O modelo RBAC (Role-Based Access Control) concede permissões baseado em:

A Atributos do usuário (ex: departamento)

B Funções ou cargos na organização

C Regras de contexto (hora, local)

D Listas de controle de acesso (ACL)

E Autenticação biométrica

✅ **Resposta correta: B**

📘 **Comentário:** RBAC associa permissões a papéis, simplificando administração.

💡 **Dica:** ABAC é mais granular usando atributos.

Q5

📌 IAM

O PAM (Privileged Access Management) tem como foco:

A Autenticação de usuários comuns

B Gerenciamento de contas com privilégios elevados

C Firewall de aplicação web

D Criptografia de dados em repouso

E Backup de logs

✅ **Resposta correta: B**

📘 **Comentário:** PAM controla acesso a contas administrativas (root, admin).

💡 **Dica:** Solução como CyberArk, cofre de senhas.

Q6

📌 FIREWALL

Uma DMZ (Zona Desmilitarizada) em uma rede corporativa serve para:

- **A** Hospedar servidores internos confidenciais
- **B** Isolar servidores públicos (web, e-mail) do acesso direto à rede interna
- **C** Centralizar logs de segurança
- **D** Realizar NAT de saída
- **E** Fazer proxy reverso

✅ **Resposta correta: B**

📘 **Comentário:** DMZ permite acesso externo a serviços sem expor a rede interna.

💡 **Dica:** Firewalls com regras específicas entre as zonas.

Q7

📌 FIREWALL

Em um NGFW (Next-Generation Firewall), uma funcionalidade adicional em relação ao firewall tradicional é:

- **A** Filtragem de pacotes stateless
- **B** Inspeção profunda de pacotes (DPI) e controle de aplicações
- **C** Apenas NAT
- **D** Roteamento estático
- **E** Balanceamento de carga

✅ **Resposta correta: B**

📘 **Comentário:** NGFW identifica aplicações (ex: Facebook) independente de porta.

💡 **Dica:** IPS integrado é comum.

Q8

📌 DEVSECOPS

A vulnerabilidade 'Cross-Site Scripting (XSS)' consiste em:

A Injeção de scripts maliciosos em páginas web visualizadas por outros usuários

B Quebra de autenticação via brute force

C Exposição de dados sensíveis em logs

D Ataque de negação de serviço

E Falsificação de requisição entre sites

✅ **Resposta correta: A**

📘 **Comentário:** XSS explora falta de sanitização de entrada.

💡 **Dica:** Codificar saída HTML (escaping) previne.

Q9

📌 DEVSECOPS

A análise SAST (Static Application Security Testing) é realizada:

A Durante a execução da aplicação

B Sobre o código-fonte sem executar o programa

C No ambiente de produção

D Através de fuzzing

E Por scanners de rede

✅ **Resposta correta: B**

📘 **Comentário:** SAST examina código em busca de padrões inseguros.

💡 **Dica:** Ferramentas: Checkmarx, SonarQube, Fortify.

Q10

📌 RESPOSTA A INCIDENTES

Segundo o NIST SP 800-61 Rev. 3, as fases da resposta a incidentes incluem:

- **A** Planejamento, detecção, contenção, erradicação, recuperação, lições aprendidas
- **B** Análise de riscos, implementação, monitoramento
- **C** Classificação, backup, restauração
- **D** Autenticação, autorização, auditoria
- **E** Prevenção, supressão, análise forense

✅ **Resposta correta: A**

📘 **Comentário:** O ciclo de resposta a incidentes bem definido minimiza danos.

💡 **Dica:** Contenção é crítica para evitar propagação.

Q11

📌 SEGURANÇA EM REDES

Um ataque DDoS (Distributed Denial of Service) tem como objetivo:

- **A** Roubar dados confidenciais
- **B** Tornar um serviço indisponível através de tráfego massivo
- **C** Instalar malware
- **D** Escalonar privilégios
- **E** Fazer engenharia social

✅ **Resposta correta: B**

📘 **Comentário:** DDoS exausta recursos da vítima (largura de banda, CPU).

💡 **Dica:** Mitigação com CDN, rate limiting, scrubbing centers.

Q12

📌 CRIPTOGRAFIA

O algoritmo AES (Advanced Encryption Standard) é um cifra:

A Assimétrica de chave pública

B Simétrica de bloco

C Hash criptográfico

D De troca de chaves

E De assinatura digital

✅ **Resposta correta: B**

📘 **Comentário:** AES é simétrico, usado para confidencialidade de dados.

💡 **Dica:** Tamanhos de chave: 128, 192 ou 256 bits.

Q13

📌 PKI

Um certificado digital X.509 contém, entre outros:

A Chave privada do titular

B Chave pública do titular e assinatura da AC

C Senha do usuário

D Logs de acesso

E Código fonte da aplicação

✅ **Resposta correta: B**

📘 **Comentário:** Certificado vincula identidade a uma chave pública, assinado pela AC.

💡 **Dica:** Padrão usado em SSL/TLS.

Q14

📌 MONITORAMENTO

Um SIEM (Security Information and Event Management) coleta e correlaciona:

A Apenas logs de firewall

B Eventos de segurança de múltiplas fontes para detectar incidentes

C Métricas de desempenho de rede

D Vulnerabilidades de código

E Tráfego de usuários individuais

✅ **Resposta correta: B**

📘 **Comentário:** SIEM agrupa logs, normaliza e aplica regras de correlação.

💡 **Dica:** Splunk, QRadar, Elastic SIEM são exemplos.

Q15

📌 CONTINUIDADE

O BIA (Business Impact Analysis) tem como principal objetivo:

A Definir o RTO e RPO para cada processo crítico

B Criar backups incrementais

C Testar o plano de contingência

D Implementar firewalls

E Realizar treinamento de conscientização

✅ **Resposta correta: A**

📘 **Comentário:** BIA identifica impactos de indisponibilidade e requisitos de recuperação.

💡 **Dica:** RTO: tempo máximo para restaurar; RPO: perda máxima de dados.

Q16

📌 QUALIDADE

A ISO 9001 aplicada à segurança da informação pode exigir:

A Certificação OWASP

B Processos definidos e melhoria contínua na gestão de segurança

C Uso exclusivo de software livre

D Backup diário obrigatório

E Firewall de última geração

✅ **Resposta correta: B**

📘 **Comentário:** ISO 9001 foca em gestão da qualidade, processos e satisfação do cliente.

💡 **Dica:** Integrada com ISO 27001.

Q17

📌 REDES

No modelo OSI, a camada responsável pelo roteamento e endereçamento lógico (IP) é:

A Física

B Enlace

C Rede

D Transporte

E Sessão

✅ **Resposta correta: C**

📘 **Comentário:** Camada de Rede (3) lida com IP, roteamento.

💡 **Dica:** Camada Transporte (4): TCP/UDP.

Q18

📌 DOCUMENTAÇÃO

Um laudo técnico pericial em segurança da informação deve conter:

A Apenas a conclusão

B Metodologia, evidências, análise e conclusão fundamentada

C Código-fonte da ferramenta

D Orçamento do serviço

E Contrato de confidencialidade

✅ **Resposta correta: B**

📘 **Comentário:** Laudo deve ser claro, objetivo e rastreável.

💡 **Dica:** Seguir normas como ISO 17025 para perícia.

Q19

📌 LEGISLAÇÃO

A Lei nº 14.133/2021 (Nova Lei de Licitações) estabelece que a contratação de soluções de TI deve:

A Priorizar sempre o menor preço

B Observar critérios de segurança da informação e governança

C Dispensar análise de riscos

D Ser feita apenas por pregão eletrônico

E Exigir certificação ISO 27001 obrigatória

✅ **Resposta correta: B**

📘 **Comentário:** A lei permite análise de técnica e preço, incluindo requisitos de segurança.

💡 **Dica:** Resolução CNMP 283/2024 reforça governança em TI.

Q20

📌 ÉTICA

O sigilo profissional na área de segurança da informação implica:

A Divulgar vulnerabilidades em redes sociais

B Proteger informações confidenciais obtidas no exercício da função

C Compartilhar credenciais com colegas

D Ignorar políticas internas

E Registrar logs pessoais

✅ **Resposta correta: B**

📘 **Comentário:** Código de ética profissional exige confidencialidade.

💡 **Dica:** Violação pode gerar sanções civis e criminais.

Q21

📌 PRIVACIDADE/LGPD

Qual algoritmo hash é considerado obsoleto e inseguro para senhas?

A bcrypt

B SHA-256

C MD5

D Argon2

E PBKDF2

✅ **Resposta correta: C**

📘 **Comentário:** MD5 tem colisões e é rápido demais, facilitando brute force.

💡 **Dica:** Usar bcrypt, Argon2 ou PBKDF2 com salt.

Q22

📌 RISCOS

No contexto de SSL/TLS, o handshake tem a função de:

A Trocar chaves de sessão e negociar cifras

B Autenticar o servidor e cliente via certificados e estabelecer canal seguro

C Apenas comprimir dados

D Realizar NAT

E Fazer load balancing

✅ **Resposta correta: B**

📘 **Comentário:** Handshake TLS negocia parâmetros e verifica identidade.

💡 **Dica:** Versões TLS 1.2 e 1.3 são seguras.

Q23

📌 IAM

O que é um IDS (Intrusion Detection System)?

A Sistema que detecta e bloqueia automaticamente ataques

B Sistema que apenas detecta e alerta sobre atividades suspeitas

C Firewall de aplicação

D Proxy reverso

E Balanceador de carga

✅ **Resposta correta: B**

📘 **Comentário:** IDS monitora e alerta; IPS também pode bloquear.

💡 **Dica:** Baseado em assinaturas ou anomalias.

Q24

📌 FIREWALL

O RPO (Recovery Point Objective) está relacionado a:

A Tempo máximo de inatividade tolerado

B Quantidade máxima de dados perdidos mensurada em tempo

C Custo do plano de continuidade

D Prioridade de recuperação

E Teste de recuperação

✅ **Resposta correta: B**

📘 **Comentário:** RPO define com que frequência os backups são feitos (perda aceitável).

💡 **Dica:** Exemplo: RPO de 1 hora → perda máxima de 1 hora de dados.

Q25

📌 DEVSECOPS

Na segurança de redes Wi-Fi, o protocolo WPA3 trouxe como melhoria:

A Criptografia WEP

B Proteção contra ataques de força bruta e chave mais robusta (SAE)

C Uso obrigatório de certificados

D Velocidade reduzida

E Compatibilidade com WPA2 apenas

✅ **Resposta correta: B**

📘 **Comentário:** WPA3 substitui PSK por Simultaneous Authentication of Equals (SAE).

💡 **Dica:** Empresarial usa 802.1X/EAP.

Q26

📌 RESPOSTA A INCIDENTES

O que é um honeypot em segurança de rede?

A Sistema que atrai atacantes para estudo e desvio

B Ferramenta de criptografia

C Backup offsite

D Firewall de próxima geração

E Analisador de protocolos

✅ **Resposta correta: A**

📘 **Comentário:** Honeypot é um isco para identificar e analisar ataques.

💡 **Dica:** Pode ser de baixa ou alta interação.

Q27

📌 CRIPTOGRAFIA

Qual o objetivo da Resolução CNJ/CNMP nº 3/2013?

A Regulamentar compras públicas

B Estabelecer diretrizes para tratamento de dados pessoais no âmbito do Judiciário e MP

C Criar a LGPD

D Definir normas de firewall

E Padronizar certificados digitais

✅ **Resposta correta: B**

📘 **Comentário:** Resolução sobre segurança, privacidade e gestão de dados pessoais nos órgãos.

💡 **Dica:** Base para políticas de segurança da informação.

Q28

📌 PKI

Em um ataque de phishing, o criminoso geralmente tenta:

- **A** Explorar vulnerabilidade de software
- **B** Enganar o usuário para obter credenciais ou instalar malware
- **C** Realizar varredura de portas
- **D** Fazer engenharia reversa
- **E** Quebrar criptografia

✅ **Resposta correta: B**

📘 **Comentário:** Phishing usa engenharia social, via e-mail ou mensagem falsa.

💡 **Dica:** Verificar remetente, URL e não clicar em links suspeitos.

Q29

📌 MONITORAMENTO

O que são VLANs (Virtual LANs) em segurança de redes?

- **A** Segmentação lógica da rede, isolando tráfego mesmo em mesmo switch
- **B** Firewall virtual
- **C** Rede sem fio
- **D** Protocolo de roteamento
- **E** Servidor de autenticação

✅ **Resposta correta: A**

📘 **Comentário:** VLANs aumentam segurança ao separar domínios de broadcast.

💡 **Dica:** Prevenir VLAN hopping com configuração adequada.

Q30

📌 CONTINUIDADE

O que é um plano de continuidade de negócios (BCP)?

A Documento que define procedimentos para manter operações críticas durante e após uma crise

B Backup de servidores

C Teste de intrusão

D Política de senhas

E Contrato de nível de serviço

✅ **Resposta correta: A**

📘 **Comentário:** BCP inclui análise de impacto e estratégias de recuperação.

💡 **Dica:** Deve ser testado periodicamente.

Q31

📌 QUALIDADE

Qual a principal finalidade do ISO 27001?

A Definir requisitos para um Sistema de Gestão de Segurança da Informação (SGSI)

B Especificar algoritmos criptográficos

C Normatizar continuidade de negócio

D Padronizar testes de intrusão

E Certificar firewalls

✅ **Resposta correta: A**

📘 **Comentário:** ISO 27001 é certificável e focada em gestão de segurança.

💡 **Dica:** Baseada em riscos e melhoria contínua (PDCA).

Q32

📌 REDES

O que significa MFA (Autenticação Multifator)?

A Uso de dois ou mais fatores de autenticação (senha + token, biometria)

B Fireware de múltiplas camadas

C Criptografia assimétrica

D Gerenciamento de privilégios

E Análise de logs

✅ **Resposta correta: A**

📘 **Comentário:** MFA aumenta significativamente a segurança contra credenciais roubadas.

💡 **Dica:** Algo que você sabe, tem e é.

Q33

📌 LEGISLAÇÃO

Em um firewall, o que é NAT (Network Address Translation)?

A Tradução de endereços de rede, permitindo que vários dispositivos usem um IP público

B Filtro de aplicações web

C Protocolo de roteamento

D Sistema de detecção de intrusão

E Proxy reverso

✅ **Resposta correta: A**

📘 **Comentário:** NAT mascara rede interna e conserva endereços IPv4.

💡 **Dica:** Tipos: estático, dinâmico, PAT (sobrecarga).

Q34

📌 DOCUMENTAÇÃO

O que é DAST (Dynamic Application Security Testing)?

A Análise estática de código

B Teste de segurança em aplicações em execução, simulando ataques

C Verificação de dependências

D Análise de configuração de servidor

E Auditoria de banco de dados

✅ **Resposta correta: B**

📘 **Comentário:** DAST explora aplicação em tempo real, sem acesso ao código.

💡 **Dica:** Ferramentas: OWASP ZAP, Burp Suite, Acunetix.

Q35

📌 PRIVACIDADE/LGPD

Indicador de comprometimento (IOC) em resposta a incidentes refere-se a:

A Evidência forense de que um ataque ocorreu (ex: hash de malware)

B Táticas e técnicas do atacante

C Plano de resposta

D Controle de acesso

E Política de backup

✅ **Resposta correta: A**

📘 **Comentário:** IOCs são artefatos observáveis (IPs maliciosos, assinaturas).

💡 **Dica:** TTPs são comportamentais (MITRE ATT&CK).

Q36

📌 RISCOS

Qual algoritmo hash é considerado obsoleto e inseguro para senhas?

A bcrypt

B SHA-256

C MD5

D Argon2

E PBKDF2

✅ **Resposta correta: C**

📘 **Comentário:** MD5 tem colisões e é rápido demais, facilitando brute force.

💡 **Dica:** Usar bcrypt, Argon2 ou PBKDF2 com salt.

Q37

📌 IAM

No contexto de SSL/TLS, o handshake tem a função de:

A Trocar chaves de sessão e negociar cifras

B Autenticar o servidor e cliente via certificados e estabelecer canal seguro

C Apenas comprimir dados

D Realizar NAT

E Fazer load balancing

✅ **Resposta correta: B**

📘 **Comentário:** Handshake TLS negocia parâmetros e verifica identidade.

💡 **Dica:** Versões TLS 1.2 e 1.3 são seguras.

Q38

📌 FIREWALL

O que é um IDS (Intrusion Detection System)?

A Sistema que detecta e bloqueia automaticamente ataques

B Sistema que apenas detecta e alerta sobre atividades suspeitas

C Firewall de aplicação

D Proxy reverso

E Balanceador de carga

✅ **Resposta correta: B**

📘 **Comentário:** IDS monitora e alerta; IPS também pode bloquear.

💡 **Dica:** Baseado em assinaturas ou anomalias.

Q39

📌 DEVSECOPS

O RPO (Recovery Point Objective) está relacionado a:

A Tempo máximo de inatividade tolerado

B Quantidade máxima de dados perdidos mensurada em tempo

C Custo do plano de continuidade

D Prioridade de recuperação

E Teste de recuperação

✅ **Resposta correta: B**

📘 **Comentário:** RPO define com que frequência os backups são feitos (perda aceitável).

💡 **Dica:** Exemplo: RPO de 1 hora → perda máxima de 1 hora de dados.

Q40

📌 RESPOSTA A INCIDENTES

Na segurança de redes Wi-Fi, o protocolo WPA3 trouxe como melhoria:

A Criptografia WEP

B Proteção contra ataques de força bruta e chave mais robusta (SAE)

C Uso obrigatório de certificados

D Velocidade reduzida

E Compatibilidade com WPA2 apenas

✅ **Resposta correta: B**

📘 **Comentário:** WPA3 substitui PSK por Simultaneous Authentication of Equals (SAE).

💡 **Dica:** Empresarial usa 802.1X/EAP.

Q41

📌 CRIPTOGRAFIA

O que é um honeypot em segurança de rede?

A Sistema que atrai atacantes para estudo e desvio

B Ferramenta de criptografia

C Backup offsite

D Firewall de próxima geração

E Analisador de protocolos

✅ **Resposta correta: A**

📘 **Comentário:** Honeypot é um isco para identificar e analisar ataques.

💡 **Dica:** Pode ser de baixa ou alta interação.

Q42

📌 PKI

Qual o objetivo da Resolução CNJ/CNMP nº 3/2013?

A Regulamentar compras públicas

B Estabelecer diretrizes para tratamento de dados pessoais no âmbito do Judiciário e MP

C Criar a LGPD

D Definir normas de firewall

E Padronizar certificados digitais

✅ **Resposta correta: B**

📘 **Comentário:** Resolução sobre segurança, privacidade e gestão de dados pessoais nos órgãos.

💡 **Dica:** Base para políticas de segurança da informação.

Q43

📌 MONITORAMENTO

Em um ataque de phishing, o criminoso geralmente tenta:

A Explorar vulnerabilidade de software

B Enganar o usuário para obter credenciais ou instalar malware

C Realizar varredura de portas

D Fazer engenharia reversa

E Quebrar criptografia

✅ **Resposta correta: B**

📘 **Comentário:** Phishing usa engenharia social, via e-mail ou mensagem falsa.

💡 **Dica:** Verificar remetente, URL e não clicar em links suspeitos.

Q44

📌 CONTINUIDADE

O que são VLANs (Virtual LANs) em segurança de redes?

A Segmentação lógica da rede, isolando tráfego mesmo em mesmo switch

B Firewall virtual

C Rede sem fio

D Protocolo de roteamento

E Servidor de autenticação

✅ **Resposta correta: A**

📘 **Comentário:** VLANs aumentam segurança ao separar domínios de broadcast.

💡 **Dica:** Prevenir VLAN hopping com configuração adequada.

Q45

📌 QUALIDADE

O que é um plano de continuidade de negócios (BCP)?

A Documento que define procedimentos para manter operações críticas durante e após uma crise

B Backup de servidores

C Teste de intrusão

D Política de senhas

E Contrato de nível de serviço

✅ **Resposta correta: A**

📘 **Comentário:** BCP inclui análise de impacto e estratégias de recuperação.

💡 **Dica:** Deve ser testado periodicamente.

Q46

📌 REDES

Qual a principal finalidade do ISO 27001?

A Definir requisitos para um Sistema de Gestão de Segurança da Informação (SGSI)

B Especificar algoritmos criptográficos

C Normatizar continuidade de negócio

D Padronizar testes de intrusão

E Certificar firewalls

✅ **Resposta correta: A**

📘 **Comentário:** ISO 27001 é certificável e focada em gestão de segurança.

💡 **Dica:** Baseada em riscos e melhoria contínua (PDCA).

Q47

📌 LEGISLAÇÃO

O que significa MFA (Autenticação Multifator)?

A Uso de dois ou mais fatores de autenticação (senha + token, biometria)

B Fireware de múltiplas camadas

C Criptografia assimétrica

D Gerenciamento de privilégios

E Análise de logs

✅ **Resposta correta: A**

📘 **Comentário:** MFA aumenta significativamente a segurança contra credenciais roubadas.

💡 **Dica:** Algo que você sabe, tem e é.

Q48

📌 DOCUMENTAÇÃO

Em um firewall, o que é NAT (Network Address Translation)?

A Tradução de endereços de rede, permitindo que vários dispositivos usem um IP público

B Filtro de aplicações web

C Protocolo de roteamento

D Sistema de detecção de intrusão

E Proxy reverso

✅ **Resposta correta: A**

📘 **Comentário:** NAT mascara rede interna e conserva endereços IPv4.

💡 **Dica:** Tipos: estático, dinâmico, PAT (sobrecarga).

Q49

📌 PRIVACIDADE/LGPD

O que é DAST (Dynamic Application Security Testing)?

A Análise estática de código

B Teste de segurança em aplicações em execução, simulando ataques

C Verificação de dependências

D Análise de configuração de servidor

E Auditoria de banco de dados

✅ **Resposta correta: B**

📘 **Comentário:** DAST explora aplicação em tempo real, sem acesso ao código.

💡 **Dica:** Ferramentas: OWASP ZAP, Burp Suite, Acunetix.

Q50

📌 RISCOS

Indicador de comprometimento (IOC) em resposta a incidentes refere-se a:

A Evidência forense de que um ataque ocorreu (ex: hash de malware)

B Táticas e técnicas do atacante

C Plano de resposta

D Controle de acesso

E Política de backup

✅ **Resposta correta: A**

📘 **Comentário:** IOCs são artefatos observáveis (IPs maliciosos, assinaturas).

💡 **Dica:** TTPs são comportamentais (MITRE ATT&CK).

Q51

📌 IAM

Qual algoritmo hash é considerado obsoleto e inseguro para senhas?

A bcrypt

B SHA-256

C MD5

D Argon2

E PBKDF2

✅ **Resposta correta: C**

📘 **Comentário:** MD5 tem colisões e é rápido demais, facilitando brute force.

💡 **Dica:** Usar bcrypt, Argon2 ou PBKDF2 com salt.

Q52

📌 FIREWALL

No contexto de SSL/TLS, o handshake tem a função de:

A Trocar chaves de sessão e negociar cifras

B Autenticar o servidor e cliente via certificados e estabelecer canal seguro

C Apenas comprimir dados

D Realizar NAT

E Fazer load balancing

✅ **Resposta correta: B**

📘 **Comentário:** Handshake TLS negocia parâmetros e verifica identidade.

💡 **Dica:** Versões TLS 1.2 e 1.3 são seguras.

Q53

📌 DEVSECOPS

O que é um IDS (Intrusion Detection System)?

A Sistema que detecta e bloqueia automaticamente ataques

B Sistema que apenas detecta e alerta sobre atividades suspeitas

C Firewall de aplicação

D Proxy reverso

E Balanceador de carga

✅ **Resposta correta: B**

📘 **Comentário:** IDS monitora e alerta; IPS também pode bloquear.

💡 **Dica:** Baseado em assinaturas ou anomalias.

Q54

📌 RESPOSTA A INCIDENTES

O RPO (Recovery Point Objective) está relacionado a:

A Tempo máximo de inatividade tolerado

B Quantidade máxima de dados perdidos mensurada em tempo

C Custo do plano de continuidade

D Prioridade de recuperação

E Teste de recuperação

✅ **Resposta correta: B**

📘 **Comentário:** RPO define com que frequência os backups são feitos (perda aceitável).

💡 **Dica:** Exemplo: RPO de 1 hora → perda máxima de 1 hora de dados.

Q55

📌 CRIPTOGRAFIA

Na segurança de redes Wi-Fi, o protocolo WPA3 trouxe como melhoria:

A Criptografia WEP

B Proteção contra ataques de força bruta e chave mais robusta (SAE)

C Uso obrigatório de certificados

D Velocidade reduzida

E Compatibilidade com WPA2 apenas

✅ **Resposta correta: B**

📘 **Comentário:** WPA3 substitui PSK por Simultaneous Authentication of Equals (SAE).

💡 **Dica:** Empresarial usa 802.1X/EAP.

Q56

📌 PKI

O que é um honeypot em segurança de rede?

A Sistema que atrai atacantes para estudo e desvio

B Ferramenta de criptografia

C Backup offsite

D Firewall de próxima geração

E Analisador de protocolos

✅ **Resposta correta: A**

📘 **Comentário:** Honeypot é um isco para identificar e analisar ataques.

💡 **Dica:** Pode ser de baixa ou alta interação.

Q57

📌 MONITORAMENTO

Qual o objetivo da Resolução CNJ/CNMP nº 3/2013?

A Regulamentar compras públicas

B Estabelecer diretrizes para tratamento de dados pessoais no âmbito do Judiciário e MP

C Criar a LGPD

D Definir normas de firewall

E Padronizar certificados digitais

✅ **Resposta correta: B**

📘 **Comentário:** Resolução sobre segurança, privacidade e gestão de dados pessoais nos órgãos.

💡 **Dica:** Base para políticas de segurança da informação.

Q58

📌 CONTINUIDADE

Em um ataque de phishing, o criminoso geralmente tenta:

A Explorar vulnerabilidade de software

B Enganar o usuário para obter credenciais ou instalar malware

C Realizar varredura de portas

D Fazer engenharia reversa

E Quebrar criptografia

✅ **Resposta correta: B**

📘 **Comentário:** Phishing usa engenharia social, via e-mail ou mensagem falsa.

💡 **Dica:** Verificar remetente, URL e não clicar em links suspeitos.

Q59

📌 QUALIDADE

O que são VLANs (Virtual LANs) em segurança de redes?

A Segmentação lógica da rede, isolando tráfego mesmo em mesmo switch

B Firewall virtual

C Rede sem fio

D Protocolo de roteamento

E Servidor de autenticação

✅ **Resposta correta: A**

📘 **Comentário:** VLANs aumentam segurança ao separar domínios de broadcast.

💡 **Dica:** Prevenir VLAN hopping com configuração adequada.

Q60

📌 REDES

O que é um plano de continuidade de negócios (BCP)?

A Documento que define procedimentos para manter operações críticas durante e após uma crise

B Backup de servidores

C Teste de intrusão

D Política de senhas

E Contrato de nível de serviço

✅ **Resposta correta: A**

📘 **Comentário:** BCP inclui análise de impacto e estratégias de recuperação.

💡 **Dica:** Deve ser testado periodicamente.

Q61

📌 LEGISLAÇÃO

Qual a principal finalidade do ISO 27001?

A Definir requisitos para um Sistema de Gestão de Segurança da Informação (SGSI)

B Especificar algoritmos criptográficos

C Normatizar continuidade de negócio

D Padronizar testes de intrusão

E Certificar firewalls

✅ **Resposta correta: A**

📘 **Comentário:** ISO 27001 é certificável e focada em gestão de segurança.

💡 **Dica:** Baseada em riscos e melhoria contínua (PDCA).

Q62

📌 DOCUMENTAÇÃO

O que significa MFA (Autenticação Multifator)?

A Uso de dois ou mais fatores de autenticação (senha + token, biometria)

B Fireware de múltiplas camadas

C Criptografia assimétrica

D Gerenciamento de privilégios

E Análise de logs

✅ **Resposta correta: A**

📘 **Comentário:** MFA aumenta significativamente a segurança contra credenciais roubadas.

💡 **Dica:** Algo que você sabe, tem e é.

Q63

📌 PRIVACIDADE/LGPD

Em um firewall, o que é NAT (Network Address Translation)?

A Tradução de endereços de rede, permitindo que vários dispositivos usem um IP público

B Filtro de aplicações web

C Protocolo de roteamento

D Sistema de detecção de intrusão

E Proxy reverso

✅ **Resposta correta: A**

📘 **Comentário:** NAT mascara rede interna e conserva endereços IPv4.

💡 **Dica:** Tipos: estático, dinâmico, PAT (sobrecarga).

Q64

📌 RISCOS

O que é DAST (Dynamic Application Security Testing)?

A Análise estática de código

B Teste de segurança em aplicações em execução, simulando ataques

C Verificação de dependências

D Análise de configuração de servidor

E Auditoria de banco de dados

✅ **Resposta correta: B**

📘 **Comentário:** DAST explora aplicação em tempo real, sem acesso ao código.

💡 **Dica:** Ferramentas: OWASP ZAP, Burp Suite, Acunetix.

Q65

📌 IAM

Indicador de comprometimento (IOC) em resposta a incidentes refere-se a:

A Evidência forense de que um ataque ocorreu (ex: hash de malware)

B Táticas e técnicas do atacante

C Plano de resposta

D Controle de acesso

E Política de backup

✅ **Resposta correta: A**

📘 **Comentário:** IOCs são artefatos observáveis (IPs maliciosos, assinaturas).

💡 **Dica:** TTPs são comportamentais (MITRE ATT&CK).

Q66

📌 FIREWALL

Qual algoritmo hash é considerado obsoleto e inseguro para senhas?

A bcrypt

B SHA-256

C MD5

D Argon2

E PBKDF2

✅ **Resposta correta: C**

📘 **Comentário:** MD5 tem colisões e é rápido demais, facilitando brute force.

💡 **Dica:** Usar bcrypt, Argon2 ou PBKDF2 com salt.

Q67

📌 DEVSECOPS

No contexto de SSL/TLS, o handshake tem a função de:

A Trocar chaves de sessão e negociar cifras

B Autenticar o servidor e cliente via certificados e estabelecer canal seguro

C Apenas comprimir dados

D Realizar NAT

E Fazer load balancing

✅ **Resposta correta: B**

📘 **Comentário:** Handshake TLS negocia parâmetros e verifica identidade.

💡 **Dica:** Versões TLS 1.2 e 1.3 são seguras.

Q68

📌 RESPOSTA A INCIDENTES

O que é um IDS (Intrusion Detection System)?

A Sistema que detecta e bloqueia automaticamente ataques

B Sistema que apenas detecta e alerta sobre atividades suspeitas

C Firewall de aplicação

D Proxy reverso

E Balanceador de carga

✅ **Resposta correta: B**

📘 **Comentário:** IDS monitora e alerta; IPS também pode bloquear.

💡 **Dica:** Baseado em assinaturas ou anomalias.

Q69

📌 CRIPTOGRAFIA

O RPO (Recovery Point Objective) está relacionado a:

A Tempo máximo de inatividade tolerado

B Quantidade máxima de dados perdidos mensurada em tempo

C Custo do plano de continuidade

D Prioridade de recuperação

E Teste de recuperação

✅ **Resposta correta: B**

📘 **Comentário:** RPO define com que frequência os backups são feitos (perda aceitável).

💡 **Dica:** Exemplo: RPO de 1 hora → perda máxima de 1 hora de dados.

Q70

📌 PKI

Na segurança de redes Wi-Fi, o protocolo WPA3 trouxe como melhoria:

A Criptografia WEP

B Proteção contra ataques de força bruta e chave mais robusta (SAE)

C Uso obrigatório de certificados

D Velocidade reduzida

E Compatibilidade com WPA2 apenas

✅ **Resposta correta: B**

📘 **Comentário:** WPA3 substitui PSK por Simultaneous Authentication of Equals (SAE).

💡 **Dica:** Empresarial usa 802.1X/EAP.

Q71

📌 MONITORAMENTO

O que é um honeypot em segurança de rede?

A Sistema que atrai atacantes para estudo e desvio

B Ferramenta de criptografia

C Backup offsite

D Firewall de próxima geração

E Analisador de protocolos

✅ **Resposta correta: A**

📘 **Comentário:** Honeypot é um isco para identificar e analisar ataques.

💡 **Dica:** Pode ser de baixa ou alta interação.

Q72

📌 CONTINUIDADE

Qual o objetivo da Resolução CNJ/CNMP nº 3/2013?

A Regulamentar compras públicas

B Estabelecer diretrizes para tratamento de dados pessoais no âmbito do Judiciário e MP

C Criar a LGPD

D Definir normas de firewall

E Padronizar certificados digitais

✅ **Resposta correta: B**

📘 **Comentário:** Resolução sobre segurança, privacidade e gestão de dados pessoais nos órgãos.

💡 **Dica:** Base para políticas de segurança da informação.

Q73

📌 QUALIDADE

Em um ataque de phishing, o criminoso geralmente tenta:

A Explorar vulnerabilidade de software

B Enganar o usuário para obter credenciais ou instalar malware

C Realizar varredura de portas

D Fazer engenharia reversa

E Quebrar criptografia

✅ **Resposta correta: B**

📘 **Comentário:** Phishing usa engenharia social, via e-mail ou mensagem falsa.

💡 **Dica:** Verificar remetente, URL e não clicar em links suspeitos.

Q74

📌 REDES

O que são VLANs (Virtual LANs) em segurança de redes?

A Segmentação lógica da rede, isolando tráfego mesmo em mesmo switch

B Firewall virtual

C Rede sem fio

D Protocolo de roteamento

E Servidor de autenticação

✅ **Resposta correta: A**

📘 **Comentário:** VLANs aumentam segurança ao separar domínios de broadcast.

💡 **Dica:** Prevenir VLAN hopping com configuração adequada.

Q75

📌 LEGISLAÇÃO

O que é um plano de continuidade de negócios (BCP)?

A Documento que define procedimentos para manter operações críticas durante e após uma crise

B Backup de servidores

C Teste de intrusão

D Política de senhas

E Contrato de nível de serviço

✅ **Resposta correta: A**

📘 **Comentário:** BCP inclui análise de impacto e estratégias de recuperação.

💡 **Dica:** Deve ser testado periodicamente.

Q76

📌 DOCUMENTAÇÃO

Qual a principal finalidade do ISO 27001?

A Definir requisitos para um Sistema de Gestão de Segurança da Informação (SGSI)

B Especificar algoritmos criptográficos

C Normatizar continuidade de negócio

D Padronizar testes de intrusão

E Certificar firewalls

✅ **Resposta correta: A**

📘 **Comentário:** ISO 27001 é certificável e focada em gestão de segurança.

💡 **Dica:** Baseada em riscos e melhoria contínua (PDCA).

Q77

📌 PRIVACIDADE/LGPD

O que significa MFA (Autenticação Multifator)?

A Uso de dois ou mais fatores de autenticação (senha + token, biometria)

B Fireware de múltiplas camadas

C Criptografia assimétrica

D Gerenciamento de privilégios

E Análise de logs

✅ **Resposta correta: A**

📘 **Comentário:** MFA aumenta significativamente a segurança contra credenciais roubadas.

💡 **Dica:** Algo que você sabe, tem e é.

Q78

📌 RISCOS

Em um firewall, o que é NAT (Network Address Translation)?

A Tradução de endereços de rede, permitindo que vários dispositivos usem um IP público

B Filtro de aplicações web

C Protocolo de roteamento

D Sistema de detecção de intrusão

E Proxy reverso

✅ **Resposta correta: A**

📘 **Comentário:** NAT mascara rede interna e conserva endereços IPv4.

💡 **Dica:** Tipos: estático, dinâmico, PAT (sobrecarga).

Q79

📌 IAM

O que é DAST (Dynamic Application Security Testing)?

A Análise estática de código

B Teste de segurança em aplicações em execução, simulando ataques

C Verificação de dependências

D Análise de configuração de servidor

E Auditoria de banco de dados

✅ **Resposta correta: B**

📘 **Comentário:** DAST explora aplicação em tempo real, sem acesso ao código.

💡 **Dica:** Ferramentas: OWASP ZAP, Burp Suite, Acunetix.

Q80

📌 FIREWALL

Indicador de comprometimento (IOC) em resposta a incidentes refere-se a:

A Evidência forense de que um ataque ocorreu (ex: hash de malware)

B Táticas e técnicas do atacante

C Plano de resposta

D Controle de acesso

E Política de backup

✅ **Resposta correta: A**

📘 **Comentário:** IOCs são artefatos observáveis (IPs maliciosos, assinaturas).

💡 **Dica:** TTPs são comportamentais (MITRE ATT&CK).

Q81

📌 DEVSECOPS

Qual algoritmo hash é considerado obsoleto e inseguro para senhas?

A bcrypt

B SHA-256

C MD5

D Argon2

E PBKDF2

✅ **Resposta correta: C**

📘 **Comentário:** MD5 tem colisões e é rápido demais, facilitando brute force.

💡 **Dica:** Usar bcrypt, Argon2 ou PBKDF2 com salt.

Q82

📌 RESPOSTA A INCIDENTES

No contexto de SSL/TLS, o handshake tem a função de:

A Trocar chaves de sessão e negociar cifras

B Autenticar o servidor e cliente via certificados e estabelecer canal seguro

C Apenas comprimir dados

D Realizar NAT

E Fazer load balancing

✅ **Resposta correta: B**

📘 **Comentário:** Handshake TLS negocia parâmetros e verifica identidade.

💡 **Dica:** Versões TLS 1.2 e 1.3 são seguras.

Q83

📌 CRIPTOGRAFIA

O que é um IDS (Intrusion Detection System)?

A Sistema que detecta e bloqueia automaticamente ataques

B Sistema que apenas detecta e alerta sobre atividades suspeitas

C Firewall de aplicação

D Proxy reverso

E Balanceador de carga

✅ **Resposta correta: B**

📘 **Comentário:** IDS monitora e alerta; IPS também pode bloquear.

💡 **Dica:** Baseado em assinaturas ou anomalias.

Q84

📌 PKI

O RPO (Recovery Point Objective) está relacionado a:

A Tempo máximo de inatividade tolerado

B Quantidade máxima de dados perdidos mensurada em tempo

C Custo do plano de continuidade

D Prioridade de recuperação

E Teste de recuperação

✅ **Resposta correta: B**

📘 **Comentário:** RPO define com que frequência os backups são feitos (perda aceitável).

💡 **Dica:** Exemplo: RPO de 1 hora → perda máxima de 1 hora de dados.

Q85

📌 MONITORAMENTO

Na segurança de redes Wi-Fi, o protocolo WPA3 trouxe como melhoria:

A Criptografia WEP

B Proteção contra ataques de força bruta e chave mais robusta (SAE)

C Uso obrigatório de certificados

D Velocidade reduzida

E Compatibilidade com WPA2 apenas

✅ **Resposta correta: B**

📘 **Comentário:** WPA3 substitui PSK por Simultaneous Authentication of Equals (SAE).

💡 **Dica:** Empresarial usa 802.1X/EAP.

Q86

📌 CONTINUIDADE

O que é um honeypot em segurança de rede?

A Sistema que atrai atacantes para estudo e desvio

B Ferramenta de criptografia

C Backup offsite

D Firewall de próxima geração

E Analisador de protocolos

✅ **Resposta correta: A**

📘 **Comentário:** Honeypot é um isco para identificar e analisar ataques.

💡 **Dica:** Pode ser de baixa ou alta interação.

Q87

📌 QUALIDADE

Qual o objetivo da Resolução CNJ/CNMP nº 3/2013?

A Regulamentar compras públicas

B Estabelecer diretrizes para tratamento de dados pessoais no âmbito do Judiciário e MP

C Criar a LGPD

D Definir normas de firewall

E Padronizar certificados digitais

✅ **Resposta correta: B**

📘 **Comentário:** Resolução sobre segurança, privacidade e gestão de dados pessoais nos órgãos.

💡 **Dica:** Base para políticas de segurança da informação.

Q88

📌 REDES

Em um ataque de phishing, o criminoso geralmente tenta:

- **A** Explorar vulnerabilidade de software
- **B** Enganar o usuário para obter credenciais ou instalar malware
- **C** Realizar varredura de portas
- **D** Fazer engenharia reversa
- **E** Quebrar criptografia

✅ **Resposta correta: B**

📘 **Comentário:** Phishing usa engenharia social, via e-mail ou mensagem falsa.

💡 **Dica:** Verificar remetente, URL e não clicar em links suspeitos.

Q89

📌 LEGISLAÇÃO

O que são VLANs (Virtual LANs) em segurança de redes?

- **A** Segmentação lógica da rede, isolando tráfego mesmo em mesmo switch
- **B** Firewall virtual
- **C** Rede sem fio
- **D** Protocolo de roteamento
- **E** Servidor de autenticação

✅ **Resposta correta: A**

📘 **Comentário:** VLANs aumentam segurança ao separar domínios de broadcast.

💡 **Dica:** Prevenir VLAN hopping com configuração adequada.

Q90

📌 DOCUMENTAÇÃO

O que é um plano de continuidade de negócios (BCP)?

A Documento que define procedimentos para manter operações críticas durante e após uma crise

B Backup de servidores

C Teste de intrusão

D Política de senhas

E Contrato de nível de serviço

✅ **Resposta correta: A**

📘 **Comentário:** BCP inclui análise de impacto e estratégias de recuperação.

💡 **Dica:** Deve ser testado periodicamente.

Q91

📌 PRIVACIDADE/LGPD

Qual a principal finalidade do ISO 27001?

A Definir requisitos para um Sistema de Gestão de Segurança da Informação (SGSI)

B Especificar algoritmos criptográficos

C Normatizar continuidade de negócio

D Padronizar testes de intrusão

E Certificar firewalls

✅ **Resposta correta: A**

📘 **Comentário:** ISO 27001 é certificável e focada em gestão de segurança.

💡 **Dica:** Baseada em riscos e melhoria contínua (PDCA).

Q92

📌 RISCOS

O que significa MFA (Autenticação Multifator)?

A Uso de dois ou mais fatores de autenticação (senha + token, biometria)

B Fireware de múltiplas camadas

C Criptografia assimétrica

D Gerenciamento de privilégios

E Análise de logs

✅ **Resposta correta: A**

📘 **Comentário:** MFA aumenta significativamente a segurança contra credenciais roubadas.

💡 **Dica:** Algo que você sabe, tem e é.

Q93

📌 IAM

Em um firewall, o que é NAT (Network Address Translation)?

A Tradução de endereços de rede, permitindo que vários dispositivos usem um IP público

B Filtro de aplicações web

C Protocolo de roteamento

D Sistema de detecção de intrusão

E Proxy reverso

✅ **Resposta correta: A**

📘 **Comentário:** NAT mascara rede interna e conserva endereços IPv4.

💡 **Dica:** Tipos: estático, dinâmico, PAT (sobrecarga).

Q94

📌 FIREWALL

O que é DAST (Dynamic Application Security Testing)?

A Análise estática de código

B Teste de segurança em aplicações em execução, simulando ataques

C Verificação de dependências

D Análise de configuração de servidor

E Auditoria de banco de dados

✅ **Resposta correta: B**

📘 **Comentário:** DAST explora aplicação em tempo real, sem acesso ao código.

💡 **Dica:** Ferramentas: OWASP ZAP, Burp Suite, Acunetix.

Q95

📌 DEVSECOPS

Indicador de comprometimento (IOC) em resposta a incidentes refere-se a:

A Evidência forense de que um ataque ocorreu (ex: hash de malware)

B Táticas e técnicas do atacante

C Plano de resposta

D Controle de acesso

E Política de backup

✅ **Resposta correta: A**

📘 **Comentário:** IOCs são artefatos observáveis (IPs maliciosos, assinaturas).

💡 **Dica:** TTPs são comportamentais (MITRE ATT&CK).

Q96

📌 RESPOSTA A INCIDENTES

Qual algoritmo hash é considerado obsoleto e inseguro para senhas?

A bcrypt

B SHA-256

C MD5

D Argon2

E PBKDF2

✅ **Resposta correta: C**

📘 **Comentário:** MD5 tem colisões e é rápido demais, facilitando brute force.

💡 **Dica:** Usar bcrypt, Argon2 ou PBKDF2 com salt.

Q97

📌 CRIPTOGRAFIA

No contexto de SSL/TLS, o handshake tem a função de:

A Trocar chaves de sessão e negociar cifras

B Autenticar o servidor e cliente via certificados e estabelecer canal seguro

C Apenas comprimir dados

D Realizar NAT

E Fazer load balancing

✅ **Resposta correta: B**

📘 **Comentário:** Handshake TLS negocia parâmetros e verifica identidade.

💡 **Dica:** Versões TLS 1.2 e 1.3 são seguras.

Q98

📌 PKI

O que é um IDS (Intrusion Detection System)?

A Sistema que detecta e bloqueia automaticamente ataques

B Sistema que apenas detecta e alerta sobre atividades suspeitas

C Firewall de aplicação

D Proxy reverso

E Balanceador de carga

✅ **Resposta correta: B**

📘 **Comentário:** IDS monitora e alerta; IPS também pode bloquear.

💡 **Dica:** Baseado em assinaturas ou anomalias.

Q99

📌 MONITORAMENTO

O RPO (Recovery Point Objective) está relacionado a:

A Tempo máximo de inatividade tolerado

B Quantidade máxima de dados perdidos mensurada em tempo

C Custo do plano de continuidade

D Prioridade de recuperação

E Teste de recuperação

✅ **Resposta correta: B**

📘 **Comentário:** RPO define com que frequência os backups são feitos (perda aceitável).

💡 **Dica:** Exemplo: RPO de 1 hora → perda máxima de 1 hora de dados.

Q100

📌 CONTINUIDADE

Na segurança de redes Wi-Fi, o protocolo WPA3 trouxe como melhoria:

A Criptografia WEP

B Proteção contra ataques de força bruta e chave mais robusta (SAE)

C Uso obrigatório de certificados

D Velocidade reduzida

E Compatibilidade com WPA2 apenas

✅ **Resposta correta: B**

📘 **Comentário:** WPA3 substitui PSK por Simultaneous Authentication of Equals (SAE).

💡 **Dica:** Empresarial usa 802.1X/EAP.

📘 Material elaborado com **questões reais da banca FGV** (base conceitual e aplicada para Segurança da Informação)

Material por **Estudando T.I.** • 📺 @EstudandoTI_Brasil

🔒 © 2025 • Questões reais FGV • Proibida reprodução não autorizada